Análisis de código con IA en DevSecOps

Francisco Noceda

Trabajo Final de Grado

Introducción

La creciente adopción de metodologías ágiles y prácticas de CI/CD ha impulsado la automatización de los procesos de desarrollo. En este contexto, **DevSecOps** surge como una evolución que integra seguridad en todo el ciclo de vida del software.

A pesar de estos avances, persisten desafíos significativos:

- Intervención manual en análisis de código y pruebas.
- Demoras en la entrega por detecciones tardías.
- Riesgo de errores humanos en la documentación técnica.

El avance de la **Inteligencia Artificial** abre nuevas posibilidades para automatizar tareas complejas y asistir a los equipos en fases críticas del desarrollo.



Caso de Estudio: Empresa Fintech

Organización dedicada al desarrollo de soluciones web para el **sector financiero** (pagos y administración de cuentas) con altos estándares de seguridad.

El flujo actual se basa en el siguiente pipeline:



Desafío: Necesidad de reducir la intervención manual y mejorar la detección temprana.

Propuesta: Pipeline Potenciado con IA

Se propone integrar un **módulo de IA** en etapas tempranas del pipeline (Pull Request) para automatizar tres capacidades críticas:

- **Detección temprana:** Identificación de vulnerabilidades antes del build.
- **Generación de pruebas:** Creación automática de casos de prueba unitarios.
- **Documentación:** Generación de descripciones contextuales del código.



Evolución del Flujo: Developer → Pull Request → AI Analysis → Build → Security Scan → Tests → Deploy

Arquitectura de la Solución

La arquitectura de la prueba de concepto se centra en la **privacidad y eficiencia** del análisis de código:

- **Ejecución Local:** Utiliza **Ollama** con el modelo **Qwen2.5-Coder 14B** para procesar el código sin enviarlo a servicios externos.
- **Integración CI/CD:** Implementada mediante **GitHub Actions**, activándose automáticamente en cada Pull Request.
- **Análisis de Diffs:** El modelo recibe solo las diferencias (*diffs*) de Git, reduciendo el consumo de recursos y el tiempo de respuesta.
- **Prompts Estructurados:** Se emplean instrucciones precisas para identificar riesgos de OWASP y generar salidas en formato **JSON**.

Este enfoque garantiza decisiones automatizadas consistentes y auditables en el pipeline DevSecOps.



Conclusiones

La implementación de modelos LLM en el pipeline DevSecOps genera impactos positivos directos en la calidad y velocidad del desarrollo.



Eficiencia y Velocidad

Detección inmediata de errores, reduciendo el retrabajo y acelerando el ciclo de vida de entrega.



Seguridad Proactiva

Identificación de vulnerabilidades (OWASP) antes del proceso de construcción del software.



Soporte al Equipo

Asistencia crítica para desarrolladores novatos, mejorando la calidad del código global.

La IA actúa como un multiplicador de capacidad, no como un reemplazo de la supervisión humana.

Líneas Futuras de Investigación

Propuestas para continuar la evolución y perfeccionamiento de la integración de IA en entornos DevSecOps.

Comparativa de Modelos

Evaluar y comparar distintos modelos de IA en tareas de análisis de código, generación de pruebas y documentación automática.

Adaptación Específica

Analizar la adaptación de los modelos a proyectos específicos para mejorar la precisión de las recomendaciones generadas.

IaC Inteligente

Incorporar capacidades de análisis de infraestructura como código (IaC) dentro del pipeline DevSecOps.

Hacia una automatización más inteligente y contextual en la seguridad del software.

Bibliografía

- **[1]** G. Kim, J. Humble, P. Debois y J. Willis, *The DevOps Handbook*. Portland, OR, USA: IT Revolution Press, 2016.
- **[2]** J. Humble y D. Farley, *Continuous Delivery: Reliable Software Releases through Build, Test, and Deployment Automation*. Boston, MA, USA: Addison-Wesley, 2010.
- **[3]** T. Davenport y R. Miller, "Working with AI: Generative AI and the Future of Software Development," *IEEE Software*, vol. 41, no. 2, pp. 10-17, 2024.
- **[4]** OpenAI, "GPT-4 Technical Report," 2023. Disponible en: https://arxiv.org/abs/2303.08774
- **[5]** OWASP Foundation, "OWASP Top 10: The Ten Most Critical Web Application Security Risks," 2021. Disponible en: https://owasp.org/www-project-top-ten/

¿Preguntas?



Gracias por su atención

Francisco Noceda